Project 1 Title: Secure Private Infrastructure Deployment with Bastion Access and IAM RoleBased Architecture

1. Project Overview

This project implements a production-grade secure AWS infrastructure for a fintech company. Application servers run in private subnets with no public IP, accessible only through a hardened Bastion Host. All EC2 instances use IAM Roles — no hardcoded credentials anywhere in the system.

2. Architecture Diagram

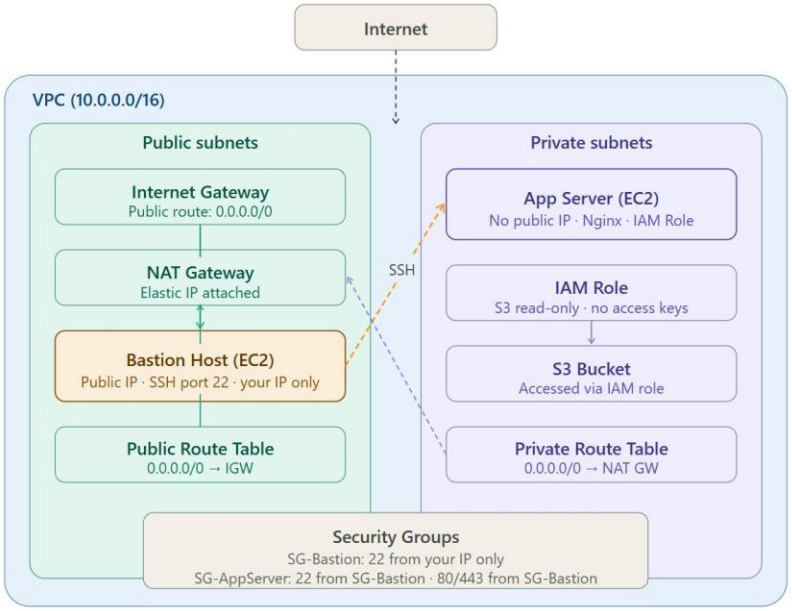

Figure 1 — architecture.png: Full AWS infrastructure layout (us-west-2)

Architecture Explanation

The infrastructure is built inside a custom VPC (fintech-vpc, vpc-0f37ec6ae5fe55c98) with CIDR 10.0.0.0/16 across two availability zones in us-west-2. Public subnets host the Bastion Host and NAT Gateway. Private subnets host the application server with no public IP and no direct internet route.

Traffic flow:

- Developer SSHs from local machine → Bastion Host (public subnet, IP-whitelisted on port 22)
- From Bastion (10.0.1.199), developer hops to App Server via private IP 10.0.3.108
- App Server reaches internet outbound-only via NAT Gateway (52.89.54.67)
- No inbound traffic from the internet can reach the private app server directly

Network Layout

Component	ID / Detail	CIDR / Value
fintech-vpc	vpc-0f37ec6ae5fe55c98	10.0.0.0/16
public-subnet-1	subnet-0752a6f323ceed782	10.0.1.0/24
public-subnet-2	subnet-00fb9854ec0d04038	10.0.2.0/24
private-subnet-1	subnet-04f832eb5d0a055cb	10.0.3.0/24
private-subnet-2	subnet-0fdc95f91346307b7	10.0.4.0/24
fintech-igw	igw-03bc679829d99a05d	Attached to fintech-vpc
fintech-nat-gw	nat-022d26bd503594c74	Public IP: 52.89.54.67
public-rt	rtb-05babe915393dcaa6	0.0.0.0/0 → IGW
private-rt	rtb-0b3b9ce01a54eb317	10.0.0.0/16 → local + NAT GW

3. Network Configuration Screenshots

3.1 VPC Details

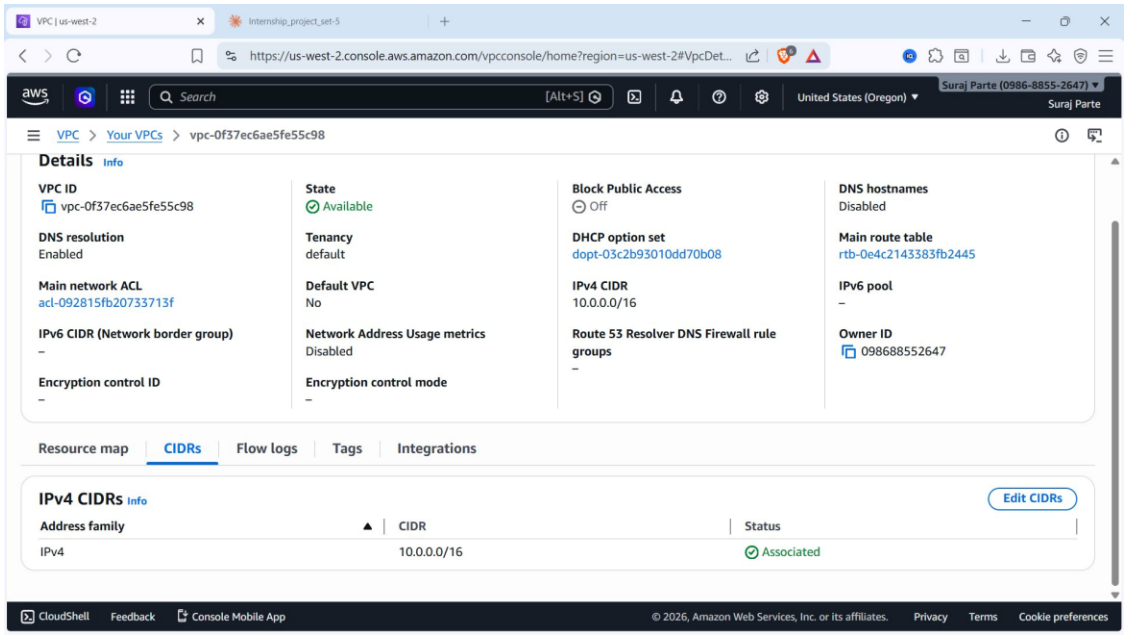

Figure 2 — 01_vpc_details.png: fintech-vpc (vpc-0f37ec6ae5fe55c98), CIDR 10.0.0.0/16, State: Available

3.2 Subnets List

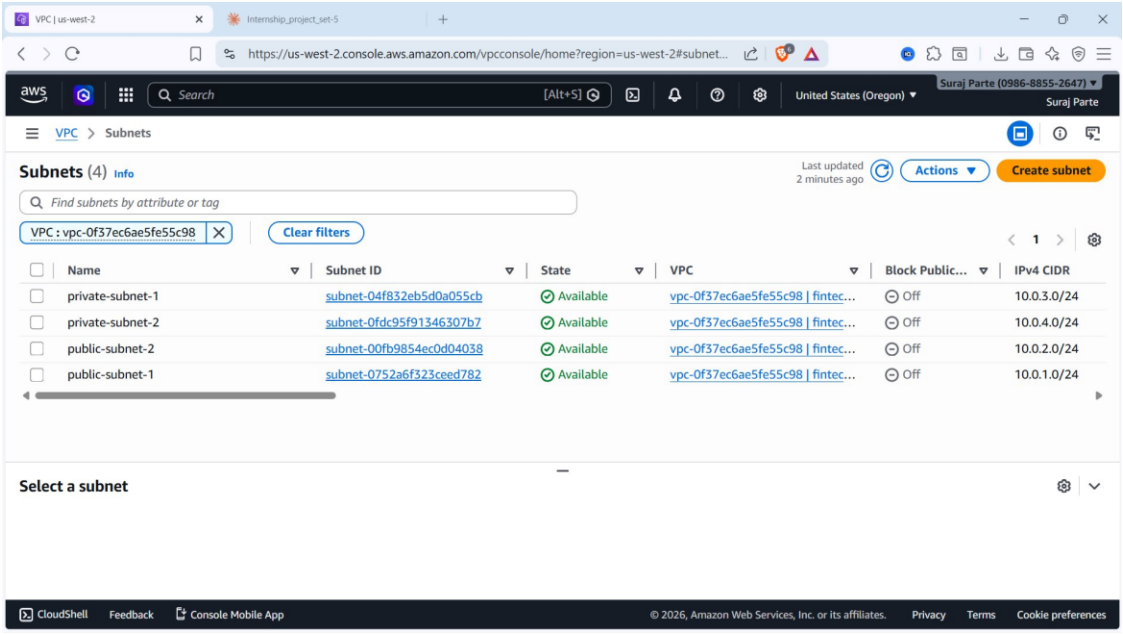

Figure 3 — 02_subnets_list.png: All 4 subnets (2 public, 2 private) in fintech-vpc — all Available

3.3 NAT Gateway

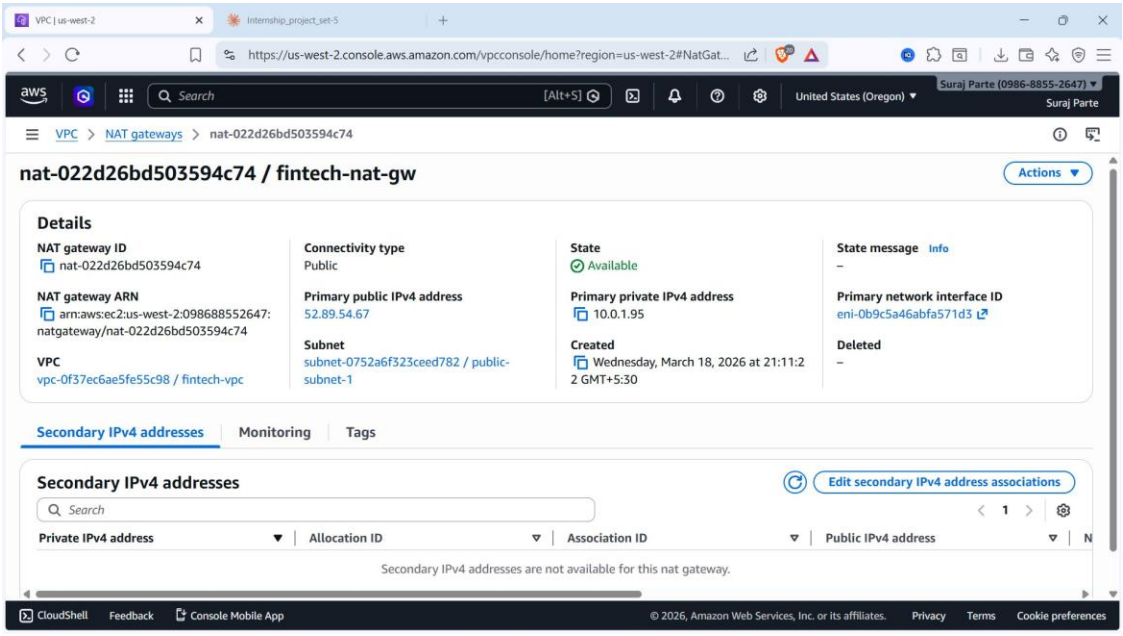

Figure 4 — 04_nat_gateway_available.png: fintech-nat-gw (nat-022d26bd503594c74) — State: Available, Public IP: 52.89.54.67, in public-subnet-1

3.4 Internet Gateway — Attached

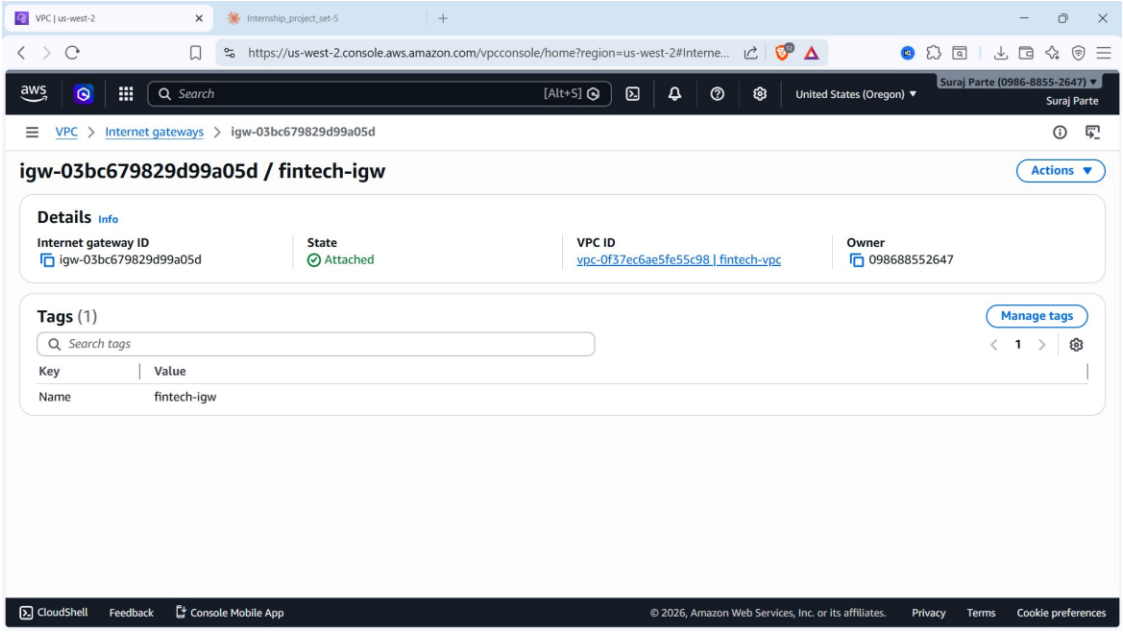

Figure 5 — 03_igw_attached.png: fintech-igw (igw-03bc679829d99a05d) — State: Attached to fintech-vpc

3.5 Public Route Table

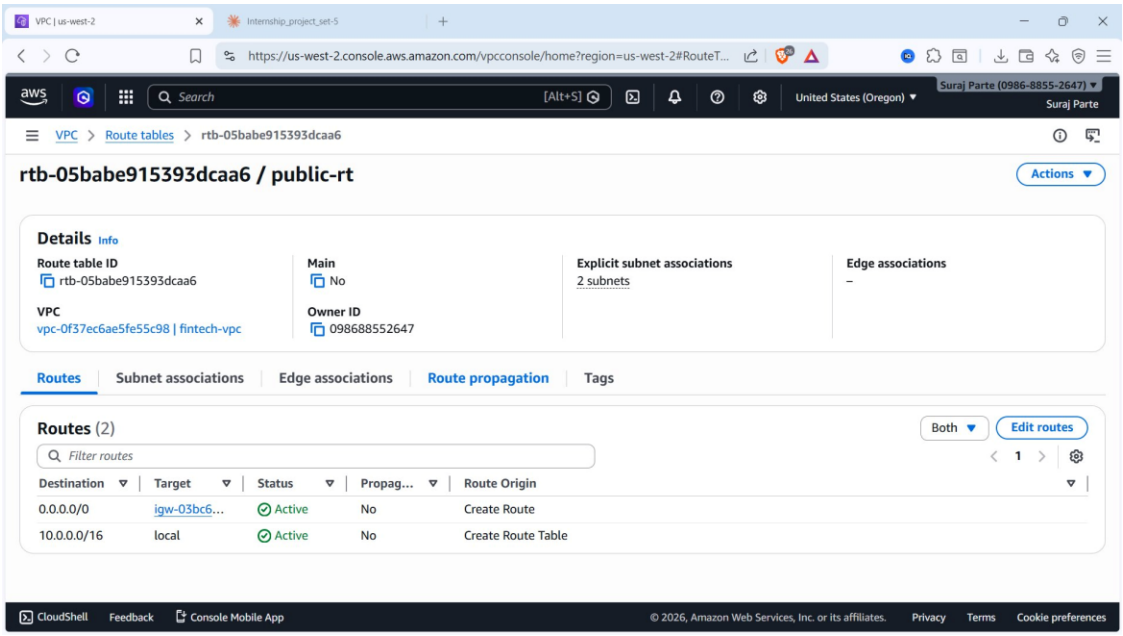

Figure 6 — 05_public_route_table.png: public-rt (rtb-05babe915393dcaa6) — Route 0.0.0.0/0 → IGW, 2 subnet associations

3.6 Private Route Table

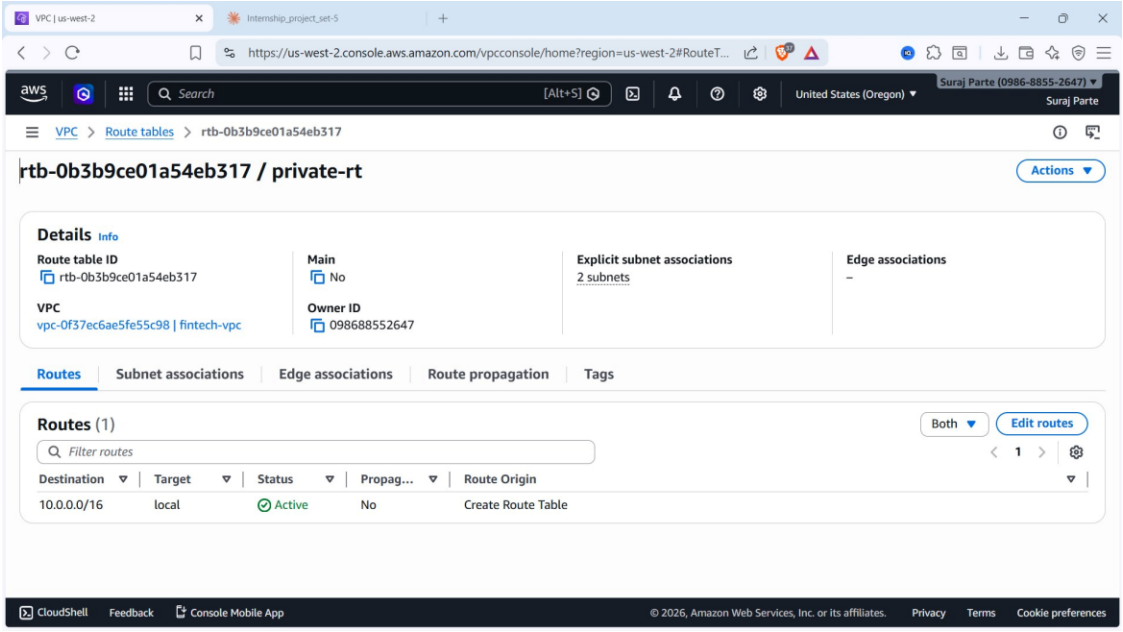

Figure 7 — 06_private_route_table.png: private-rt (rtb-0b3b9ce01a54eb317) — 10.0.0.0/16 local only, 2 subnet associations

4. Security Design Decisions

4.1 Bastion Host

- Deployed in public-subnet-1, Public IP 16.148.97.77 (instance i-053dc425d1536ab9f)
- SSH (port 22) restricted to your IP only — security group bastion-sg (sg-0651c18e2244fd108)
- Password login disabled — key-pair finetech-key.pem only
- Only 1 inbound rule exists — no other ports open

4.2 Private Application Server

- No public IP — private IP 10.0.3.108 only (instance i-04fdf0c9f8ced234f)
- Deployed in private-subnet-1 — unreachable from internet directly
- Security group appserver-sg (sg-0b22d17276040db6a) — SSH and HTTP from bastion-sg only
- Outbound routes through NAT Gateway — no direct internet exposure

4.3 Security Groups

Security Group	Rule	Source
bastion-sg (sg-0651c18e2244fd108)	SSH — Port 22	Your IP /32 only
appserver-sg (sg-0b22d17276040db6a)	SSH — Port 22	bastion-sg reference
appserver-sg (sg-0b22d17276040db6a)	HTTP — Port 80	bastion-sg reference

4.4 IAM Role

- Role ec2-role (arn:aws:iam::098688552647:role/ec2-role) with AmazonS3ReadOnlyAccess
- Attached to app-server via instance profile arn:aws:iam::098688552647:instance-profile/ec2-role
- No ~/.aws/credentials on server — temporary credentials via instance metadata

5. Security Group Configuration Screenshots

5.1 Bastion Security Group (bastion-sg)

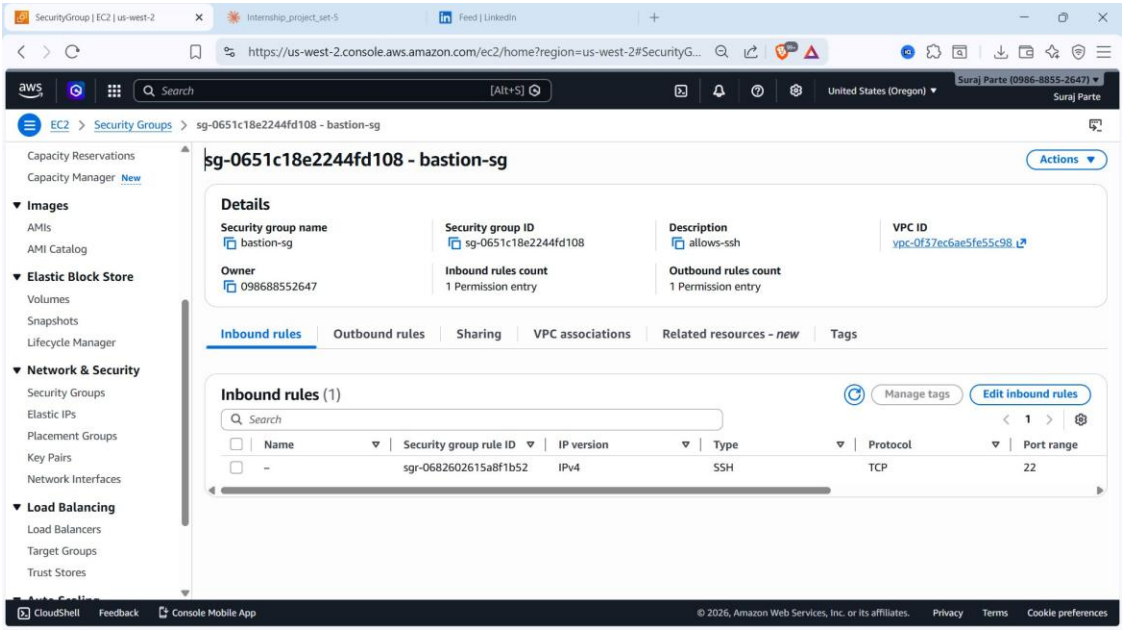

Figure 8 — 07_sg_bastion_inbound.png: bastion-sg — 1 inbound rule, SSH port 22, IPv4 only

5.2 App Server Security Group (appserver-sg)

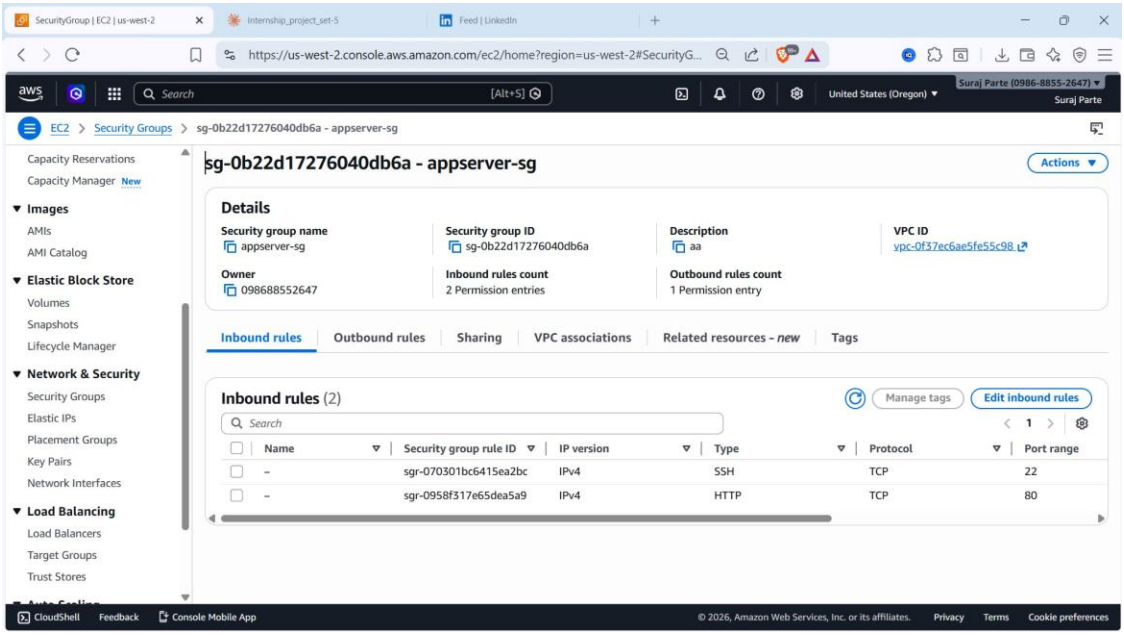

Figure 9 — 08_sg_appserver_inbound.png: appserver-sg — 2 inbound rules, SSH port 22 and HTTP port 80

6. Bastion Access Proof

6.1 Bastion Host EC2 Details

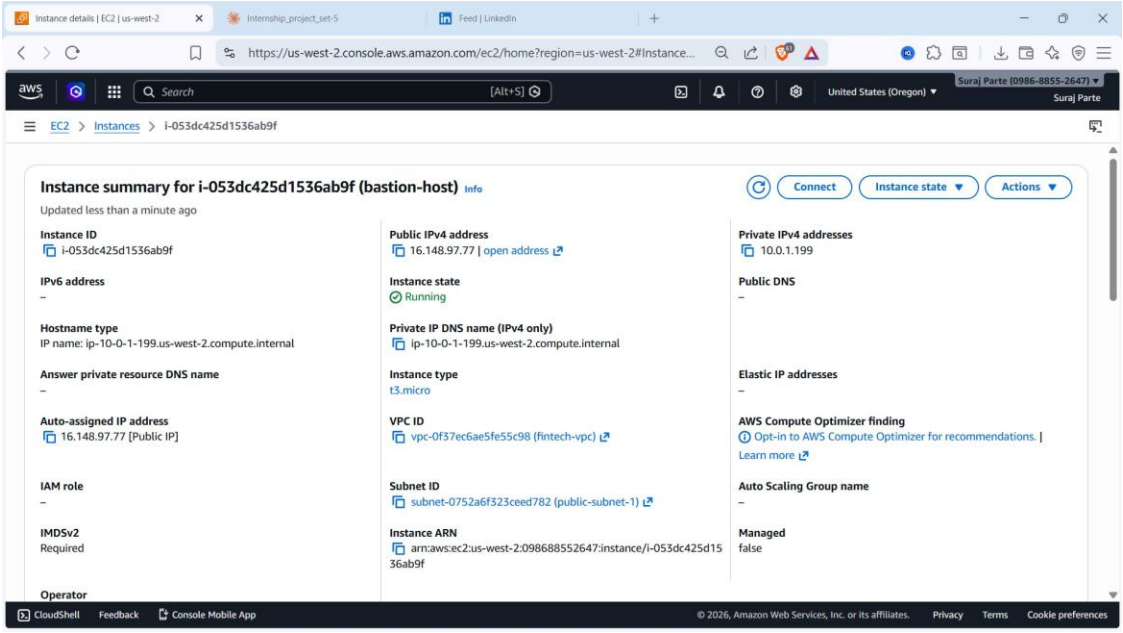

Figure 10 — 09_bastion_ec2_details.png: bastion-host (i-053dc425d1536ab9f) — Public IP 16.148.97.77, Subnet public-subnet-1, VPC fintech-vpc, Running

6.2 App Server EC2 Details

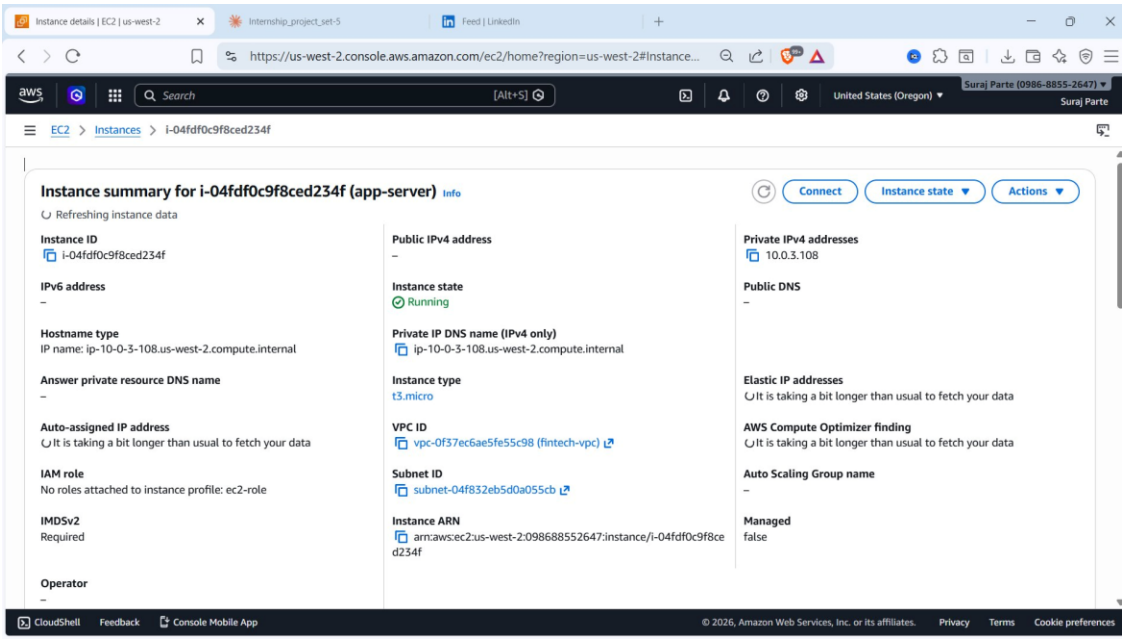

Figure 11 — 10_appserver_ec2_details.png: app-server (i-04fdf0c9f8ced234f) — No Public IP, Private IP 10.0.3.108, Subnet private-subnet-1, IAM role: ec2-role

6.3 Successful SSH — Bastion to App Server

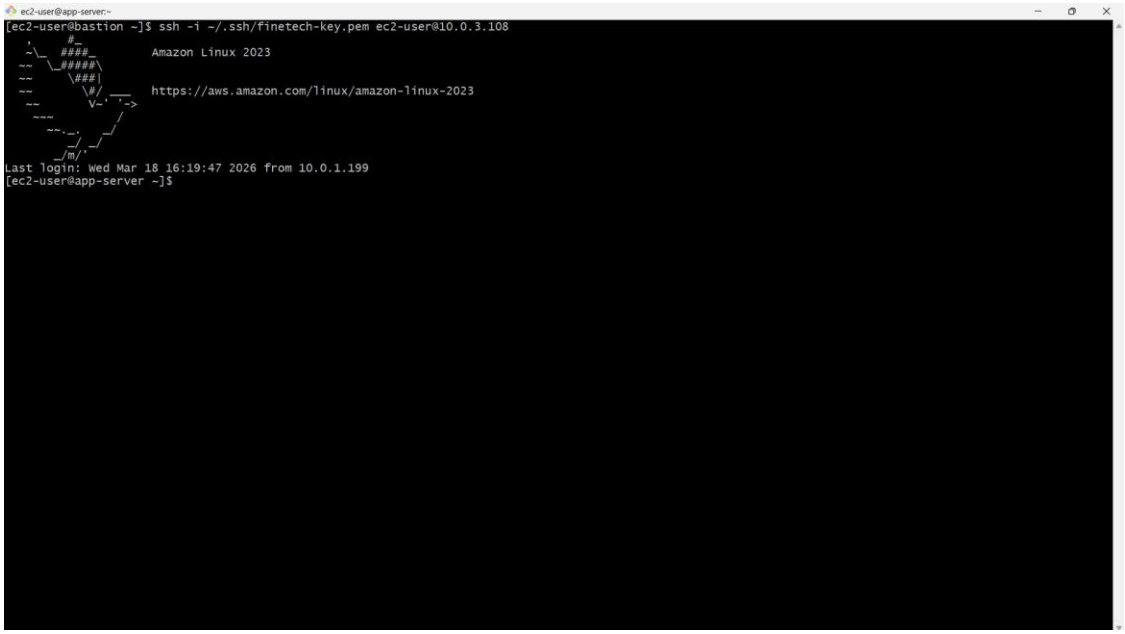

Figure 12 — 11_ssh_into_bastion.png: SSH from bastion (10.0.1.199) into app-server (10.0.3.108) — login successful, Amazon Linux 2023

6.4 Direct SSH Timeout — Security Validation

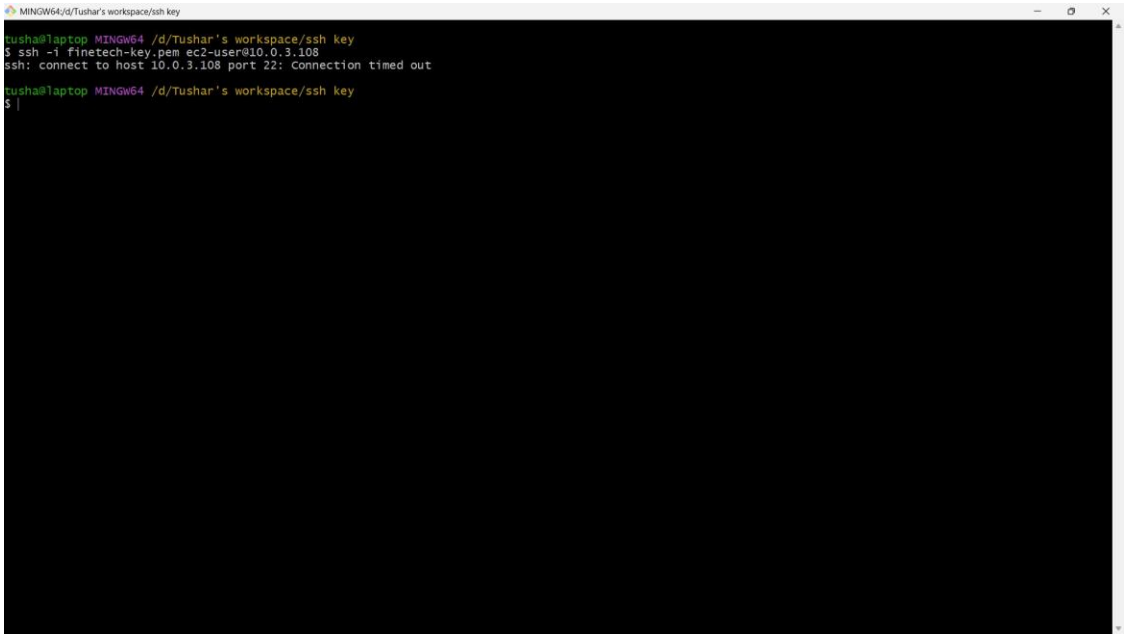

Figure 13 — 13_direct_ssh_timeout.png: Direct SSH to 10.0.3.108 from local machine — Connection timed out. Private server unreachable from internet.

7. IAM Role Attachment Proof

7.1 IAM Role Policy

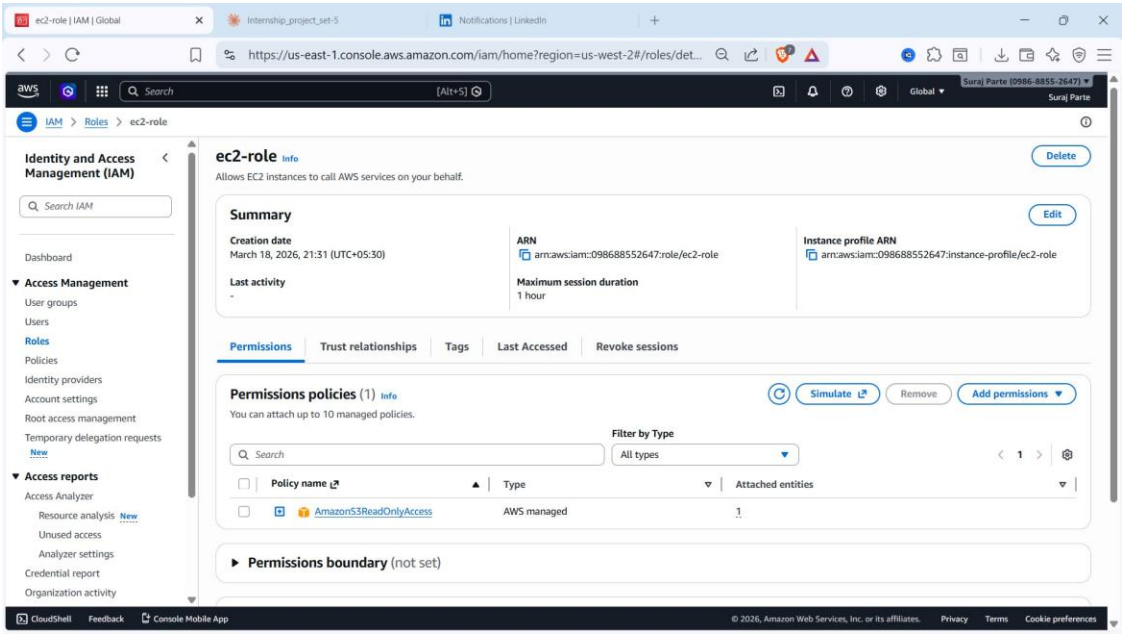

Figure 14 — 14_iam_role_policy.png: ec2-role with AmazonS3ReadOnlyAccess (AWS managed) — 1 attached entity

7.2 Role Attached to App Server

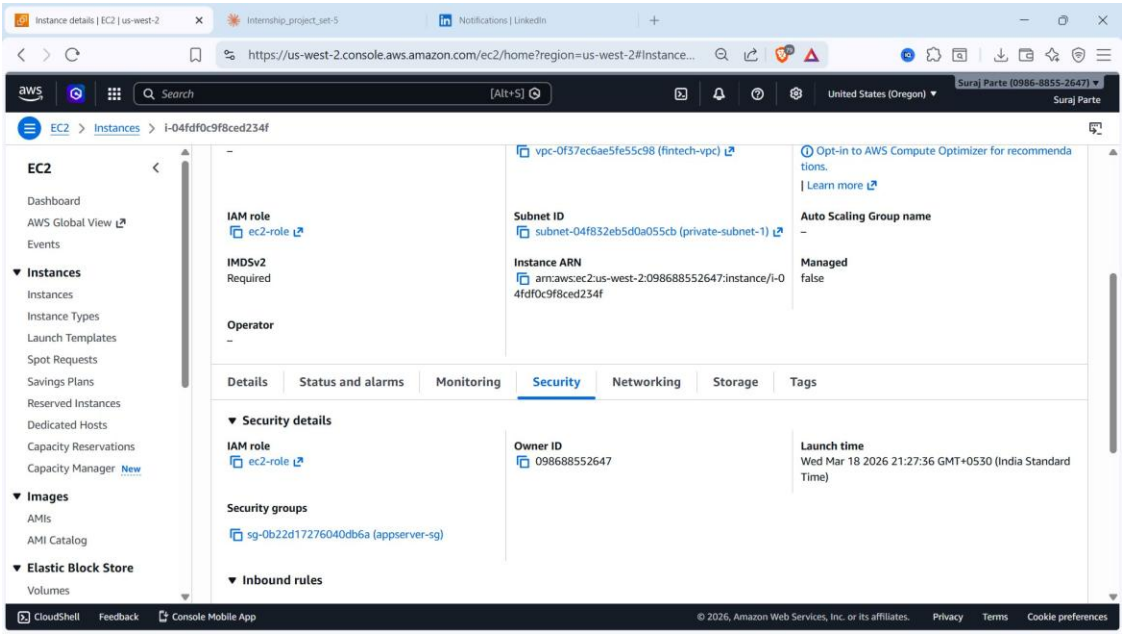

Figure 15 — 15_iam_role_attached_ec2.png: app-server Security tab — IAM role: ec2-role, Security group: appserver-sg, Subnet: private-subnet-1

8. Access Flow

```
# Step 1 — On local machine
chmod 400 finetech-key.pem
scp -i finetech-key.pem finetech-key.pem ec2-user@16.148.97.77:~/.ssh/
ssh -i finetech-key.pem ec2-user@16.148.97.77

# Step 2 — Inside bastion, hop to app server
chmod 400 ~/.ssh/finetech-key.pem
ssh -i ~/.ssh/finetech-key.pem ec2-user@10.0.3.108

# Step 3 — Verify IAM role (no credentials file)
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/
# Returns: ec2-role
```

9. Setup Steps Summary

Step	Action	Location
1	Create VPC fintech-vpc (10.0.0.0/16)	VPC Console
2	Create 4 subnets (2 public, 2 private)	VPC → Subnets
3	Create and attach Internet Gateway fintech-igw	VPC → Internet Gateways
4	Create NAT Gateway fintech-nat-gw in public-subnet-1	VPC → NAT Gateways
5	Create public-rt — 0.0.0.0/0 → IGW	VPC → Route Tables
6	Create private-rt — 0.0.0.0/0 → NAT GW	VPC → Route Tables
7	Create bastion-sg — SSH port 22 from your IP only	EC2 → Security Groups
8	Create appserver-sg — SSH + HTTP from bastion-sg	EC2 → Security Groups
9	Launch bastion-host in public-subnet-1 (public IP on)	EC2 → Launch Instance
10	Launch app-server in private-subnet-1 (no public IP)	EC2 → Launch Instance
11	Create ec2-role with S3ReadOnly, attach to app-server	IAM → Roles

10. Lessons Learned

- Never assign public IPs to application servers — private subnets with Bastion access is the correct secure pattern
- Security group chaining (referencing another SG as source) is more secure than IP-based rules for internal traffic
- IAM Instance Profiles eliminate static credentials entirely — no access keys to rotate, leak, or store
- NAT Gateway provides necessary outbound internet for private instances with zero inbound exposure
- Route tables are the key control point — a private subnet with a route to IGW is effectively public
- Restricting Bastion SSH to a /32 IP dramatically reduces attack surface compared to 0.0.0.0/0
- The jump-host pattern (Local → Bastion → Private EC2) enforces two access control layers in practice
- The private-rt screenshot revealed it only had a local route — the NAT route must be explicitly added

11. Technologies Used

Technology	Purpose
Amazon VPC	Network isolation — custom CIDR, subnets, route tables
Amazon EC2	Bastion Host (t3.micro) and private application server (t3.micro)
Internet Gateway	Inbound/outbound internet access for public subnet resources
NAT Gateway	Outbound-only internet access for private subnet instances
IAM Roles	Credential-free AWS service access via instance profile
Amazon S3	Storage accessed via IAM role — no static access keys
Security Groups	Stateful firewall — enforces least privilege per resource